

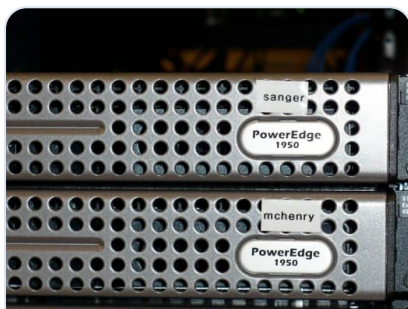
ADMINISTRATION LINUX

Guide de l'audit Linux

Audit des droits Linux



MATÉRIEL QUE TU CROISES DANS CE LABORATOIRE



Serveur

Fournit fichiers, messagerie ou site web aux autres

Photos issues de Wikimedia Commons : Serveur, Florence Devouard, CC BY-SA 4.0.

Ce guide accompagne le laboratoire d'audit des droits. Il résume les commandes à connaître et la façon de lire leur résultat.

1 Lire une ligne ls -l

TERMINAL

```
-rwxr-xr-x 1 root root 1043 Mar 28 09:12 /opt/scripts/deploy.sh
```

ZONE	EXEMPLE	SENS
Type	-	fichier ordinaire (d = dossier, l = lien)
Propriétaire	rwX	lecture, écriture, exécution
Groupe	r-X	lecture et exécution
Autres	r-X	lecture et exécution

Chaque droit vaut un nombre : r = 4, w = 2, x = 1. On additionne par groupe : rwX = 7, r-X = 5, r-- = 4. Le mode rwxr-xr-x s'écrit donc 755.



2 Ce qui doit alerter

- ◆ Un droit d'écriture pour « autres » (le dernier groupe) sur un script : n'importe quel compte peut le modifier.
- ◆ Un script modifiable par tous et lancé par le cron de root : c'est une escalade de privilèges.
- ◆ Un bit SUID (un s à la place du x du propriétaire) sur un outil qui sait lancer des commandes, comme find.
- ◆ Une règle sudoers NOPASSWD: ALL : un simple compte devient root sans mot de passe.
- ◆ Un second compte avec l'identifiant 0 dans /etc/passwd : il est root de fait.

3 Commandes de vérification

TERMINAL

```
find / -perm -4000 -type f 2>/dev/null      # fichiers SUID
find / -perm -002 -type f 2>/dev/null      # fichiers modifiables par tous
awk -F: '$3 == 0 {print $1}' /etc/passwd    # comptes root
sudo -l -U utilisateur                     # droits sudo d'un compte
crontab -l -u root                         # tâches planifiées de root
```

4 Méthode

- 1 Repérer ce qui sort de l'ordinaire par rapport à un système sain.
- 2 Noter la preuve (chemin, ligne, compte) pour chaque anomalie.
- 3 Évaluer l'impact : qui peut exploiter cela, avec quels droits ?
- 4 Proposer une correction : chmod, retrait du SUID, règle sudoers plus stricte, suppression du compte.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite. Pour copier les commandes sans coupure de ligne, ouvre la [version texte](#).